

# **Final Report**

---

## **External Penetration Testing Assessment Report**

Name: Mahzabin Muntaha

Student ID: 202320000443

Serial Number:8

### **Course:**

Applied Penetration Testing Engineer

**Submission Date:** 18 May 2026

## Section 1 — Executive Summary

This document outlines the outcomes of three cybersecurity exercises, namely Active Reconnaissance, OWASP Juice Shop, and the Blue (MS17-010) vulnerable Windows machine. The assessments demonstrate how poor security configurations, vulnerable applications, and missing updates can expose systems to major cyber threats. During testing, vulnerabilities enabled attackers to gather system intelligence, bypass authentication controls, and gain elevated privileges, ultimately resulting in complete compromise. These results underline the importance of effective security practices, regular maintenance, and secure software implementation.

## Section 2 — Scope of Assessment

### Included Targets:

- TryHackMe Active Reconnaissance environment
- OWASP Juice Shop testing platform
- Blue vulnerable Windows machine affected by EternalBlue (MS17-010)

### Excluded Targets:

- Operational or production systems
- Third-party hosted environments
- Denial of Service (DoS) testing activities

## Section 3 — Assessment Methodology

The security assessment was carried out using a step-by-step penetration testing framework:

1. **Information Gathering** — Detecting reachable hosts and collecting system-related details.
2. **Security Analysis** — Identifying weaknesses in software, applications, and services.
3. **Controlled Exploitation** — Testing vulnerabilities to confirm security flaws.
4. **Privilege Escalation & Post-Exploitation** — Obtaining higher access rights and retrieving sensitive information.
5. **Reporting Process** — Summarizing findings, analyzing risks, and providing mitigation guidance.

## Section 4 — Active Reconnaissance Summary

**Tools Applied:** ping, traceroute, telnet, netcat, and browser developer tools.

### Findings:

- System information was unintentionally exposed through headers, SSL/TLS certificates, and JavaScript files.
- ICMP packets revealed host responsiveness and possible operating system details.
- Traceroute results disclosed aspects of the network infrastructure.
- Banner grabbing exposed service-related version information.

### **Security Impact:**

- Leaked technical details may help attackers identify suitable attack vectors.
- Understanding network routes improves the effectiveness of targeted attacks.

### **Suggested Mitigation:**

- Remove unnecessary metadata and banner exposure.
- Limit network discovery responses such as ICMP and traceroute.
- Replace outdated protocols like Telnet with secure alternatives such as SSH.

## **Section 5 — OWASP Juice Shop Summary**

### **Findings:**

- Sensitive information was disclosed through insecure application functionality.
- Weak authentication controls allowed unauthorized login attempts.
- SQL Injection vulnerabilities were discovered in authentication inputs.

### **Security Impact:**

- Unauthorized individuals may gain access to user accounts.
- Confidential information could be exposed or manipulated.
- Privilege escalation may grant attackers administrative access.

### **Suggested Mitigation:**

- Prevent SQL Injection by using prepared statements or parameterized queries.
- Validate and sanitize user-provided input data.
- Deploy stronger authentication and access control mechanisms.

## **Section 6 — Blue Room Summary**

**Discovered Vulnerability:** MS17-010 (EternalBlue SMB Exploit)

### **Findings:**

- SMB service was accessible through port 445.
- Remote code execution was achieved using the EternalBlue exploit.
- SYSTEM-level access privileges were successfully obtained.
- Password hashes were extracted and later cracked.

### **Security Impact:**

- Attackers could completely take over the compromised machine.
- Stolen credentials increase the risk of lateral movement within a network.
- Sensitive files and system resources become vulnerable to unauthorized access.

### **Suggested Mitigation:**

- Install Microsoft's MS17-010 security update immediately.
- Disable SMBv1 protocol to reduce vulnerability exposure.
- Restrict access to SMB-related ports, especially port 445.
- Enable additional credential protection mechanisms.

## **Section 7 — Overall Security Recommendations**

- Regularly update systems and software with the latest security patches.
- Follow secure software development principles to reduce vulnerabilities.
- Disable unsupported or insecure legacy services.
- Maintain ongoing system monitoring and logging.
- Schedule frequent vulnerability assessments and penetration testing.

## **Section 8 — Conclusion**

The exercises demonstrate that vulnerabilities in applications, network services, and unpatched operating systems can significantly increase security risks. Organizations can reduce the likelihood of compromise by maintaining secure configurations, implementing safe coding practices, and ensuring timely patch management.